

Client Data Handling Standard

Synthetic policy for local retrieval and citation demos

Policy ID	DATA-STD-004
Owner	Data Governance Office
Effective Date	2026-02-01
Review Cycle	Annual

Document Summary

Defines classification, storage, sharing, retention, and approved handling rules for synthetic client data examples.

This document is fictional and contains no real client, employee, vendor, or confidential enterprise information.

1. Purpose and Data Classes

This standard defines how employees and approved service providers must classify, store, share, and dispose of client information in fictional enterprise workflows. The examples are synthetic and are not based on any real client data.

Client data must be classified as Public, Internal, Confidential, or Restricted. Confidential data includes client names paired with account information, onboarding documents, tax identifiers, financial statements, and non-public contact details. Restricted data includes government identifiers, authentication secrets, sanctions alerts, and regulated personal data requiring heightened controls.

2. Storage and Access Controls

Confidential and Restricted client data must be stored only in approved enterprise repositories with access logging, role-based access control, encryption at rest, and multi-factor authentication.

Employees may not store Confidential or Restricted client data in personal drives, unmanaged collaboration tools, local downloads folders, consumer note-taking applications, or unapproved browser extensions.

Access must follow least privilege. Managers must review access to repositories containing Restricted data at least quarterly and remove users who no longer require access for an active business purpose.

3. Sharing and Transmission

Confidential data may be shared internally only with employees who have a documented business need. External sharing requires an approved secure channel, recipient validation, and, when applicable, a confidentiality agreement.

Restricted data may not be sent through standard email unless the message uses approved encryption and the recipient is validated immediately before transmission. Bulk Restricted data transfers require Data Governance approval and a transfer record.

Screenshots containing client data must be treated according to the highest data class visible in the image. Redaction must remove the underlying text or pixels, not merely cover them with a shape.

4. Retention and Disposal

Client records must be retained only for the approved retention period listed in the relevant business record schedule. Duplicates and working files must be deleted when no longer required for the business purpose.

Disposal of Confidential and Restricted data must use approved secure deletion, repository lifecycle controls, or certified destruction for physical media. Employees must not manually delete records subject to legal hold.

5. AI and Analytics Use

Client data may be used for analytics or AI only when the use case is approved, the data class is permitted for the tool, and the output is reviewed for leakage of Confidential or Restricted information.

Restricted client data must not be pasted into public AI assistants, personal chatbots, public code assistants, or unapproved model training workflows. Synthetic examples may be used for testing when they cannot reasonably be linked to a real client.

6. Incident Reporting

Suspected misdirected emails, exposed links, lost devices, unauthorized repository access, or accidental upload to an unapproved service must be reported to the Security Operations intake channel within one hour of discovery.

Employees must preserve evidence and avoid deleting logs, messages, or files related to a suspected data handling incident unless directed by Legal or Security Operations.